

JUSTIFICATION REVIEW DOCUMENT
FAR 13.5 SIMPLIFIED PROCEDURES FOR CERTAIN COMMERCIAL ITEMS
SOLE SOURCE JUSTIFICATION AND APPROVAL

Program/Equipment: The U.S. Army Cyber School (USACyS) has a recurring requirement to procure SANS Innovation Center's Global Information Assurance Certification (GIAC) prep course curriculum and certification to establish, administer, and execute an Advanced Cyber Operations -Academics (AOC-A) functional course.

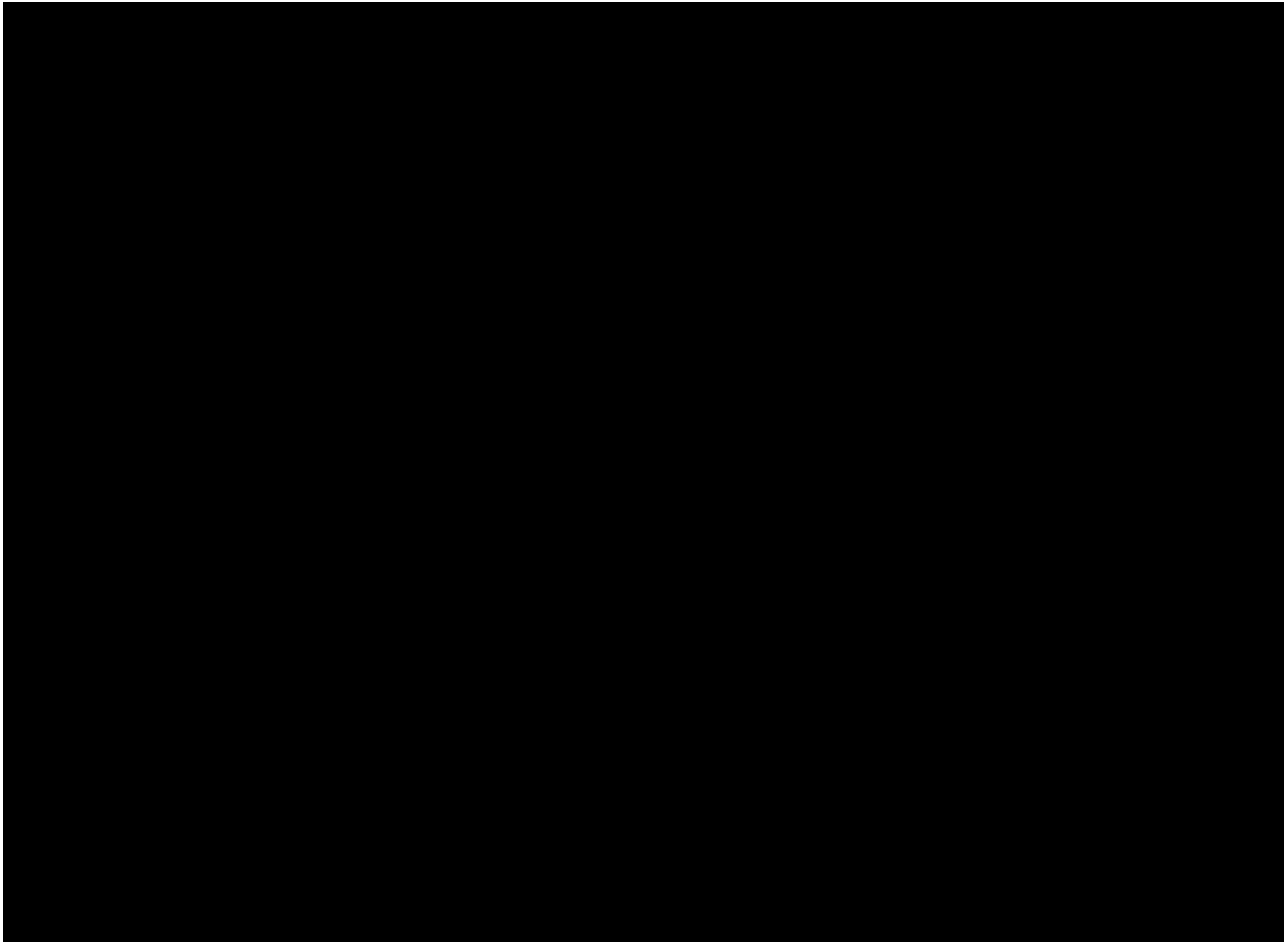
Authority: Simplified Procedures for Certain Commercial Items, Title 41 U.S.C. 1901 as implemented by FAR 13.5.

Amount:

Contracting Officer: Ashley Scott
Contracting Officer
Email: ashley.t.scott3.civ@army.mil

DSN: 780-9208
Date: 30 OCT 24

Reviews: I have reviewed this justification and find it adequate to support sole source.



**FAR 13.5 Simplified Procedures for Certain Commercial Items
Sole Source Justification and Approval**

1. Contracting Activity: U.S. Army Mission and Installation Contracting Command (MICC)-Fort Eisenhower, 271 Heritage Park Lane, Bldg. 35200, Fort Eisenhower, GA 30905.

2. Description of Action: U.S. Army Cyber School (USACyS) requests a firm-fixed-price contract with SANS Innovation Center, located at 11200 Rockville Pike, Suite 200 North Bethesda, MD 20852, for the listed Global Information Assurance Certification (GIAC) certifications and SANS prep course curriculum. The Government projects fiscal year 2025 award for January 2025 and FY25 Operations and Maintenance, Army (OMA) funds will be used. This requirement is subject to availability of funds due to the Government is currently operating under a continuing resolution.

An acquisition plan is not required because this procurement does not meet the threshold at Defense Federal Acquisition Regulation Supplement 207.103(d)(i)(B).

This action is a follow-on to contract W91249-24-C-0012. That contract was not competed under authority Simplified Procedures for Certain Commercial Items, Title 41 U.S.C. 1901 as implemented by FAR 13.5 Exclusive Licensing Agreements.

3. Description of Services: SANS Innovation Center will provide two iterations of eight SANS courses (SEC560, SEC542, SEC580, SEC565, SEC599, SEC660, FOR508, SEC699), six GIACs (GPEN, GWAPT, GDAT, GCFA, GXPN, and GRTP), and two practice tests for each GIAC over the base performance period of 12 months. In addition, SANS Innovation Center will provide instruction and certification opportunities for all classes in the 500 and 600 series as requested to account for future changes to AOC-A training requirements. If FAR Clause 52.217-8 is executed for an additional 6 months of performance, then SANS Innovation Center will provide eight SANS courses (SEC560, SEC542, SEC580, SEC565, SEC599, SEC660, FOR508, SEC699), six GIACs (GPEN, GWAPT, GDAT, GCFA, GXPN, and GRTP), and two practice tests for each GIAC during this 6-month period.

Technical Salient Characteristics for each Course are listed below a Learning Outcome (LO) / Terminal Learning Objective (TLO) and the Enabling Learning Objectives (ELOs) support activities associated to each LO/TLO.

- a. Course: SEC 560 - Enterprise Penetration Testing
Certification: GIAC Penetration Tester (GPEN)
Learning Outcome/TLO: Learn how to plan, prepare, and execute a penetration test in a modern enterprise.
 - Perform detailed reconnaissance to aid in social engineering, phishing, and making well-informed attack decisions

- Scan target networks using best-of-breed tools to identify systems and targets that other tools and techniques may have missed
 - Perform safe and effective password guessing to gain initial access to the target environment, or to move deeper into the network
 - Exploit target systems in multiple ways to gain access and measure real business risk
 - Execute extensive post-exploitation to move further into the network
 - Use privilege escalation techniques to elevate access on Windows or Linux systems, or the Microsoft Windows domain
 - Perform internal reconnaissance and situational awareness tasks to identify additional targets and attack paths
 - Execute lateral movement and pivoting to further extend access to the organization and identify risks missed by surface scans
 - Crack passwords using modern tools and techniques to extend or escalate access
 - Use multiple Command and Control (C2, C&C) frameworks to manage and pillage compromised hosts
 - Attack the Microsoft Windows domain used by most organizations
 - Execute multiple Kerberos attacks, including Kerberoasting, Golden Ticket, and Silver Ticket attacks
 - Conduct Azure reconnaissance
 - Execute Azure Active Directory (AD) password spray attacks
 - Execute commands in Azure using compromised credentials
 - Develop and deliver high-quality reports
- b. Course: SEC 542 - Web App Penetration Testing and Ethical Hacking
Certification: GIAC Web Application Penetration Tester (GWAPT)
Learning Outcome/TLO: Understand common web application flaws, as well as how to identify and exploit them with the intent of demonstrating the potential business impact.
- Apply OWASP's methodology to your web application penetration tests to ensure they are consistent, reproducible, rigorous, and under quality control
 - Analyze the results from automated web testing tools to validate findings, determine their business impact, and eliminate false positives
 - Manually discover key web application flaws
 - Use Python to create testing and exploitation scripts during a penetration test
 - Discover and exploit SQL Injection flaws to determine true risk to the victim organization

- Understand and exploit insecure deserialization vulnerabilities with ysoserial and similar tools
 - Create configurations and test payloads within other web attacks
 - Fuzz potential inputs for injection attacks with ZAP, Burp's Intruder and ffuf
 - Explain the impact of exploitation of web application flaws
 - Analyze traffic between the client and the server application using tools such as the Zed Attack Proxy and BurpSuite Pro to find security issues within the client-side application code
 - Manually discover and exploit Cross-Site Request Forgery (CSRF) attacks
 - Manually discover and exploit Server-Side Request Forgery (SSRF) attacks
 - Use the Browser Exploitation Framework (BeEF) to hook victim browsers, attack client software and the network, and evaluate the potential impact that XSS flaws have within an application
 - Use the Nuclei tool to perform scans of target web sites/servers
 - Perform two complete web penetration tests, one during the five sections of course instruction, and the other during the Capture the Flag exercise
- c. Course: SEC 580 - Metasploit for Enterprise Penetration Testing
Certification: None
Learning Outcome/TLO: Learn how to apply the capabilities of the Metasploit Framework in a comprehensive penetration testing and vulnerability assessment regimen, and according to a thorough methodology for performing effective tests.
- Guided Overview of Metasploit's Architecture and Components
 - Deep Dive into the Msfconsole Interface, including Logging and Session Manipulation
 - Careful and Effective Exploitation
 - The Ultimate Payload: The Metasploit Meterpreter In-Depth
 - Metasploit's Integration into a Professional Testing Methodology
 - Automation with Meterpreter Scripts to Achieve More in Less Time with Consistency
 - Using Metasploit as a Recon Tool
 - Using Auxiliary Modules to Enhance your Testing
 - Ultra-Stealthy Techniques for Bypassing Anti-Virus Tools
 - Client-Side Attacks - Using One-Liners instead of Executables
 - Port and Vulnerability Scanning with Metasploit, Including Integration with Nmap, Nessus, and Qualys
 - Capturing SMB Credentials and Metasploit's awesome PowerShell integration
 - Merciless Pivoting: Routing Through Exploited Systems
 - Exposing Metasploit's Routing Using SOCKS Proxies

- Privilege Escalation Attacks
 - Metasploit's Integration with Other Tools
 - Making the Most of Windows Payloads
 - Advanced Pillaging - Gathering Useful Data from Compromised Machines
 - Evading Countermeasures to Mimic Sophisticated Attackers
 - Scripting Up the Meterpreter to Customize Your Own Attacks
 - Persisting Inside an Environment
 - Carefully Examining Your Attack's Forensic Artifacts
 - Integration with CrackMapExec, a Stand-alone Testing Tool
 - Command and Control via Third-Party Infrastructure
- d. Course: SEC 565 - Red Team Operations and Adversary Emulation
Certification: GIAC Red Team Professional Certification (GRTF)
Learning Outcome/TLO: Learn how to plan and execute end-to-end Red Teaming engagements that leverage adversary emulation, including the skills to organize a Red Team, consume threat intelligence to map against adversary tactics, techniques, and procedures (TTPs), emulate those TTPs, report and analyze the results of the Red Team engagement, and ultimately improve the overall security posture of the organization.
- Use threat intelligence to study adversaries for emulation
 - Build an adversary emulation plan
 - Map actions to MITRE® ATT&CK™ to aid in communicating with the Blue Team
 - Establish resilient, advanced C2 infrastructure
 - Maintain operational security throughout an engagement
 - Leverage initial access to elevate and propagate through a network
 - Enumerate and attack Active Directory
 - Collect and exfiltrate sensitive data in a safe manner
 - Close an engagement, deliver value, and plan for retesting
- e. Course: SEC 599 - Defeating Advanced Adversaries-Purple Team Tactics & Kill Chain Defenses
Certification: GIAC Defending Advanced Threats (GDAT)
Learning Outcome/TLO: Learn security controls aimed at stopping, detecting, and responding to your adversaries through a purple team strategy.
- Leveraging MITRE ATT&CK as a "common language" in the organization
 - Building your own Cuckoo sandbox solution to analyze payloads

- Developing effective group policies to improve script execution (including PowerShell, Windows Script Host, VBA, HTA, etc.)
 - Highlighting key bypass strategies for script controls (Unmanaged Powershell, AMSI bypasses, etc.)
 - Stopping 0-day exploits using ExploitGuard and application whitelisting
 - Highlighting key bypass strategies in application whitelisting (focus on AppLocker)
 - Detecting and preventing malware persistence
 - Leveraging the Elastic stack as a central log analysis solution
 - Detecting and preventing lateral movement through Sysmon, Windows event monitoring, and group policies
 - Blocking and detecting command and control through network traffic analysis
 - Leveraging threat intelligence to improve your security posture
- f. Course: SEC 660 - Advanced Penetration Testing, Exploit Writing, and Ethical Hacking
- Certification: GIAC Exploit Researcher and Advanced Penetration Tester (GXPN)
- Learning Outcome/TLO: Learn how to model the abilities of an advanced attacker to find significant flaws in a target environment and demonstrate the business risk associated with these flaws.
- Perform fuzz testing to enhance your company's SDL process
 - Exploit network devices and assess network application protocols
 - Escape from restricted environments on Linux and Windows
 - Test cryptographic implementations
 - Model the techniques used by attackers to perform 0-day vulnerability discovery and exploit development
 - Develop more accurate quantitative and qualitative risk assessments through validation
 - Demonstrate the needs and effects of leveraging modern exploit mitigation controls
 - Reverse-engineer vulnerable code to write custom exploits
 - Exploit routing protocol implementations such as OSPF
 - Bypass different types of NAC implementations
 - Exploit patch updates
 - Perform man-in-the-middle attacks to remove SSL
 - Perform IPv6 attacks
 - Exploit poor cryptographic implementations using CBC bit flipping attacks and hash length extension attacks

- Hijack network booting environments
 - Exploit virtualization implementations
 - Write Python scripts to automate testing
 - Write fuzzers to trigger bugs in software
 - Reverse-engineer applications to locate code paths and identify potential exploitable bugs
 - Debug Linux applications
 - Debug Windows applications
 - Write exploits against buffer overflow vulnerabilities
 - Bypass exploit mitigations such as ASLR, DEP, stack canaries, SafeSEH, etc
 - Use ROP to bypass or disable security controls
- g. Course: FOR 508 - Advanced Incident Response, Threat Hunting, and Digital Forensics
Certification: GIAC Certified Forensic Analyst (GCFA)
Learning Outcome/TLO: Learn advanced skills to hunt, identify, counter, and recover from a wide range of threats within enterprise networks, including APT nation-state adversaries, organized crime syndicates, and hactivists.
- Understand attacker tradecraft to perform compromise assessments
 - Detect how and when a breach occurred
 - Quickly identify compromised and infected systems
 - Perform damage assessments and determine what was read, stolen, or changed
 - Contain and remediate incidents of all types
 - Track adversaries and develop threat intelligence to scope a network
 - Hunt down additional breaches using knowledge of adversary techniques
 - Learn and master the tools, techniques, and procedures necessary to effectively hunt, detect, and contain a variety of adversaries and to remediate incidents
 - Detect and hunt unknown live, dormant, and custom malware in memory across multiple Windows systems in an enterprise environment
 - Hunt through and perform incident response across hundreds of unique systems simultaneously using PowerShell, Velociraptor, and the SIFT Workstation
 - Identify and track malware beaconing outbound to its command and control (C2) channel via memory forensics, registry analysis, and network connection residue
 - Determine how the breach occurred by identifying the root cause, the beachhead systems and initial attack mechanisms

- Identify living off the land techniques, including malicious use of PowerShell and WMI
 - Target advanced adversary anti-forensics techniques like hidden and time-stamped malware, along with living off the land techniques used to move in the network and maintain an attacker's presence
 - Use memory analysis, incident response, and threat hunting tools in the SIFT Workstation to detect hidden processes, malware, attacker command lines, rootkits, network connections, and more
 - Track user and attacker activity second-by-second on the system you are analyzing through in-depth timeline and super-timeline analysis
 - Recover data cleared using anti-forensics techniques via Volume Shadow Copy/Restore Point analysis
 - Identify lateral movement and pivots within your enterprise across your endpoints, showing how attackers transition from system to system without detection
 - Understand how the attacker can acquire legitimate credentials - including domain administrator rights - even in a locked-down environment
 - Track data movement as attackers collect critical data and shift it to exfiltration collection points
 - Recover data cleared using anti-forensics techniques via Volume Shadow Copy and Restore Point analysis and artifact carving
 - Use collected data to perform effective remediation across the entire enterprise
 - Build advanced forensics skills to counter anti-forensics and data hiding from technical subjects
- h. Course: SEC 699 - Purple Team Tactics-Adversary Emulation for Breach Prevention & Detection
Certification: None
Learning Outcome/TLO: Learn how adversarial techniques can be emulated and detected.
- A course section on typical automation strategies such as Ansible, Docker and Terraform. These can be used to deploy a full multi-domain enterprise environment for adversary emulation at the press of a button
 - Building a proper process, tooling, and planning for purple teaming
 - Building adversary emulation plans that mimic real-life threat actors such as APT-28, APT-34, and Turla in order to execute these plans using tools such as Covenant and Caldera

- In-depth techniques such as Kerberos Delegation attacks, Attack Surface Reduction / Applocker bypasses, AMSI, Process Injection, COM Object Hi-jacking and many more...
- SIGMA rule-building to detect the above techniques

Base Period: 14 JAN 2025 to 13 JAN 2026

Value: [REDACTED]

FAR Clause 52.217-8: 14 JAN 2026 to 13 JUL 2026

Value: [REDACTED]

Total Value: [REDACTED]

4. Authority Cited: Simplified Procedures for Certain Commercial Items, Title 41 U.S.C. 1901 as implemented by FAR 13.5: Exclusive Licensing Agreements.

5. Reason for Authority Cited:

a. The USACyS was mandated by USCYBERCOM per the course growth sponsorship memorandum to establish, administer, and execute an Advanced Cyberspace Operations Course-Academics (AOC-A) Functional Course. SANS Innovation Center, LLC developed the AOC-A course in connection with and through its National Security Agency contract H98230-22-D- 0004 for Pilots 1-3. SANS Innovation Center subsequently delivered Pilot 4 under Army Cyber School contract W91249-24-C-0012. This contract provided 19 weeks and 4 days of in-person training consisting of eight specific SANS courses (SEC560, SEC542, SEC580, SEC565, FOR508, SEC599, SEC660, and SEC699), six corresponding GIAC certifications (GPEN, GWAPT, GDAT, GCFA, GXPEN, and GRTP), and two practice tests for each GIAC. SANS Innovation Center is the sole provider of SANS training and GIAC certifications. There are no agents or dealers authorized to represent themselves as resellers of SANS products.

b. Alternatives.

1) Provide other enhanced training: This will not be a viable solution because the USACyS does not have any other courses of training within the schoolhouse that meets the specific technical training that the USCYBERCOM needs to train their personnel.

2) Use in-house personnel/expertise: The USACyS does not have the instructors that possess the correct technical expertise to instruct the training course needed by the USCYBERCOM personnel.

3) Suspend operations: The USACyS cannot suspend the operations due to the impact of the overall mission that pertains to operations and readiness to meet the requirements set forth by the USCYBERCOM Commander.

c. Impact if justification is not approved: The USACyS will not be able to support the execution of the AOC-A Functional Course and meet the mandated requirement set

forth by USCYBERCOM to meet their overall objective to establish, administer, and execute an Advanced Cyberspace Operations Course-Academics (AOC-A) Functional Course.

6. Efforts to Obtain Competition: The Contracting Officer shall publish the notices required by FAR 5.201. Accordingly, a sources sought notice was posted to SAM.GOV by MICC-Fort Eisenhower on 31 October 2024. The sources sought notice included a statement of salient characteristics, and detailed specifications of the requirement. There were four (4) responses received from multiple vendors stating they could provide the requirement. However, the capability statement provided by SANS was the only vendor deemed technically capable by the requiring activity upon review. Market research consisted of internet research of vendors website, literature reviews, other professional resources and industry events.

In addition, pursuant to Title 48 CFR Part 19.705-2, as implemented by Federal Acquisition Regulation FAR 19.705-2, the Contracting Officer must determine whether a proposed contractual action requires a subcontracting plan. For this requirement, the Contracting Officer has determined that there are no subcontracting possibilities and that no subcontracting plan is required. This determination shall include a detailed rationale and be placed in the contract file.

7. Actions to Increase Competition: No other competition is available. SANS Innovation Center is the sole provider of SANS training and Global Information Assurance Certification ("GIAC") certifications. A sole source letter was provided by SANS stating they have the exclusive right to produce official SANS Curriculum and deliver SANS training through SANS Certified Instructors. The USACyS continually researches sources of information to determine the availability of other providers of the GIAC certifications in a package along with commercially available training that could potentially meet the Government's need in the open market.

8. Market Research: USACyS conducted research in September 2024 through internet inquiries and on the General Services Administration (GSA) Advantage web site to determine if required products are available through Federal Supply Schedules (FSS). The required products were not available through FSS. USCYBERCOM validated this requirement for the USACyS to deliver the AOC-A functional course to their military and civilian personnel. The specific identified SANS curriculum was approved after conducting extensive market research of multiple companies to provide specific modules to include the GIAC certifications. Results of the market research concluded that SANS is the only vendor that provides the core cyber related curriculum and GIAC certifications required to conduct training. This process was conducted in coordination with a partner agency and cannot be deviated from without the expressed direction of the USCYBERCOM J7. AOC-A consists of eight SANS Innovation Center courses and six corresponding GIAC certifications. A sources sought notice was posted by the Contracting Specialist at MICC-Fort Eisenhower to SAM.GOV on 31 October 2024 and a total of four (4) responses were received. The capabilities statements were reviewed by the Contracting Officer and the requiring activity. It was deemed that only

one (1) vendor, SANS, could provide the sought requirement.

A search of the Dynamic Small Business System and keywords "Global Information Assurance Certification" returned no firms with the capability. SANS has provided a sole source letter stating "SANS is the sole provider for the Global Information Assurance Certification (GIAC). There are no agents or dealers authorized to represent themselves as resellers of SANS products."

9. Interested Sources:

Vendor Name and UEI	Is Vendor Current in SAM.gov?	Bus. Size	Did Vendor provide a capability statement?	COR Technical Evaluation of Capability
SANS	Yes	Large	Yes	Capable
Antisyphon Training	Yes	Small	Yes	Not Capable - Does not meet curriculum requirements as directed by USCYBERCOM
UKI	Yes	Small	Yes	Not Capable - Does not meet curriculum requirements as directed by USCYBERCOM
WITS LLC	Yes	Small	Yes	Not Capable - Does not meet curriculum requirements as directed by USCYBERCOM

10. Other Facts:

a. This is a recurring requirement to establish, administer, and execute the Advanced Cyberspace Operations Course-Academics (AOC-A) Functional Course. The previous effort was a sole source award to SANS Innovation Center.

Contract number: W91249-24-C-0012

Vendor: SANS Innovation Center

Award date: 18 July 2024

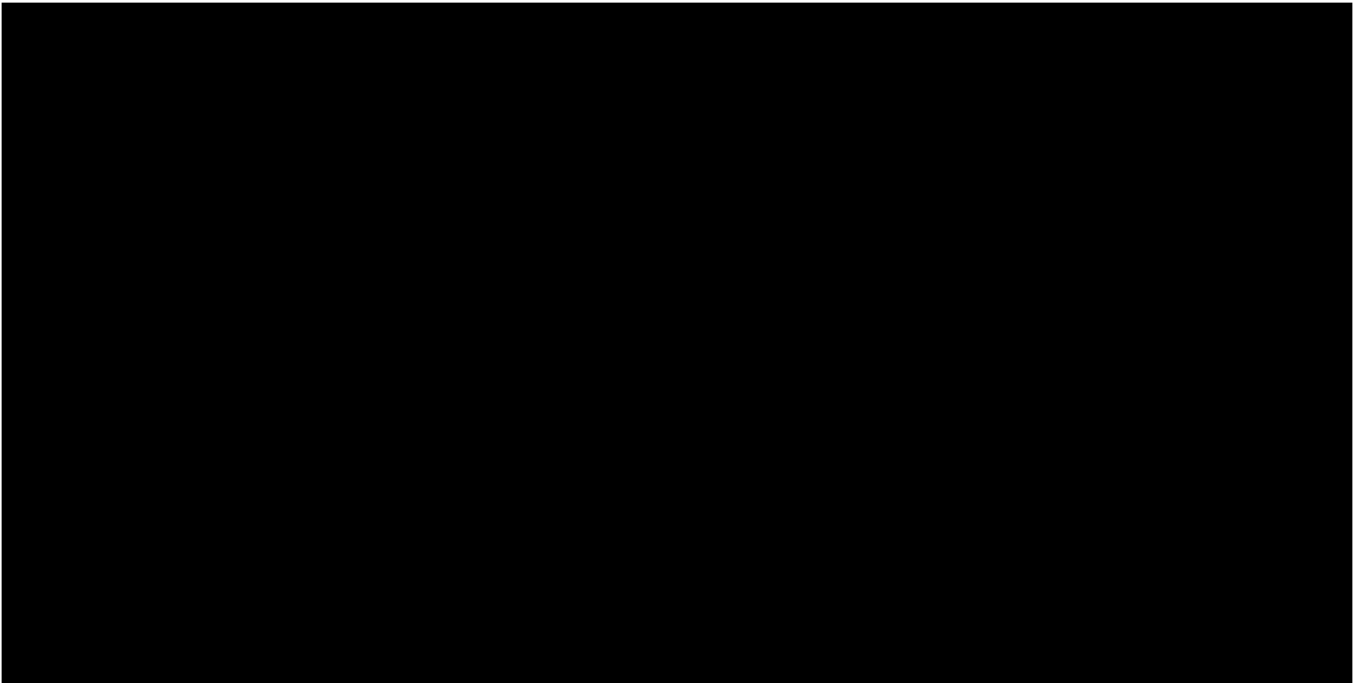
Competitive Status: Sole Source

Authority cited: Simplified Procedures for Certain Commercial Items, Title 41 U.S.C. 1901 as implemented by FAR 13.5. Exclusive Licensing agreements.

b. There are no current services available at the USACyS to execute the USCYBERCOM requirements.

c. The specific need to use SANS Innovation Center, LLC was the explicit requirement from USCYBERCOM that training be conducted via in-person modularity for the following courses: SEC560, SEC542, SEC580, FOR508, SEC660, SEC699, SEC599, SEC565. These courses are only offered by SANS LLC after extensive market research conducted by USCYBERCOM.

d. This mandate to establish, administer, and execute an Advanced Cyberspace Operations Course-Academics (AOC-A) Functional Course was communicated from USCYBERCOM J-7 via signed course growth sponsorship memorandum.



13. Fair and Reasonable Cost Determination: I hereby determine that the anticipated cost or price to the Government for this contract action will be fair and reasonable. This determination will be made using price analysis. As a part of this basis, certified cost or pricing data is not required because the items being acquired are considered commercial.

SCOTT.ASHLEY. [redacted]
[redacted] _____
Ashley Scott
Contracting Officer

Date: See digital signature

14. Contracting Officer Certification: I certify that this justification is accurate and complete to the best of my knowledge and belief.

SCOTT.ASHLEY. [redacted]
[redacted] _____
Ashley Scott
Contracting Officer

Date: See digital signature



Approval

Based on the foregoing justification, I hereby approve the procurement of three iterations of the 19-week, 4 day AOC-A functional course consisting of eight SANS Innovation Center commercially available courses (SEC560, SEC542, SEC580, SEC565, FOR508, SEC599, SEC660, and SEC699) and six corresponding GIAC certifications (GPEN, GWAPT, GDAT, GCFA, GXPEN, AND GRTP) and two practice tests for each of these certifications, on a sole source basis pursuant to the authority of the Simplified Procedures for Certain Commercial Items, Title 41 United States Code Section 1901 as implemented by Federal Acquisition Regulation 13.5. The estimated value of the contract is [REDACTED] for a 12-month period of performance from approximately 14 January 2025 to 13 January 2026 when two iterations would be conducted, and includes FAR Clause 52.217-8 for an additional 6-month period of 14 January 2026 to 13 July 2026 when a third iteration would be conducted. The approval is subject to availability of funds, and provided that the supplies herein described have otherwise been authorized for acquisition.

KUKES.SCOTT [REDACTED]

SCOTT D. KUKES

Alternate Advocate for Competition

U.S. Army Mission and Installation Contracting Command, JBSA Fort Sam Houston, TX